Algoritmi e Protocolli per la Sicurezza
Project Work
WP1: Modello

Gennaro Foschillo
Francesco Vittorio Allocca

May 19, 2026

1 Scenario del progetto e Obiettivi

Nei sistemi democratici moderni, la conduzione di elezioni sicure, trasparenti e verificabili è un requisito fondamentale. Il voto elettronico, inteso come la raccolta e il conteggio di voti tramite sistemi digitali, promette di aumentare l'accessibilità, ridurre i costi e accelerare lo scrutinio. Tuttavia, la sua adozione solleva criticità di sicurezza profonde:

- Violazione della segretezza del voto;
- Manipolazione o alterazione dei voti espressi;
- Impossibilità per il singolo elettore di verificare che il proprio voto sia stato conteggiato correttamente;
- Attacchi alla disponibilità del sistema durante le operazioni di voto;
- Coercizione o acquisto di voto, facilitati dalla mancanza di un ambiente fisicamente controllato.

Un protocollo ideale per il voto elettronico deve garantire al contempo la segretezza del voto, la verificabilità del risultato e la resistenza a manipolazioni, anche da parte degli stessi gestori del sistema.
L'obiettivo di questo progetto è dunque la realizzazione di un protocollo di voto elettronico sicuro, considerando il contesto di un'elezione di tipo referendum binario, in cui ogni elettore può esprimere una sola preferenza tra due opzioni possibili. La scelta di questo contesto riduce notevolmente la complessità progettuale del modello, permettendo quindi di concentrarsi sulle proprietà fondamentali per un sistema di voto sicuro, ovvero: autenticità, unicità del voto, segretezza, integrità, verificabilità individuale e verificabilità universale.

2 Obiettivo del Work Package

Questo work package si occuperà di definire il modello che si intende realizzare, fornendone una descrizione ad alto livello. Verranno definiti i vari attori onesti del sistema, ovvero le

entità coinvolte per la corretta realizzazione del sistema ed il suo utilizzo.
Successivamente, verranno definiti i Threat Model, ovvero le entità che potenzialmente possono compromettere il corretto funzionamento del sistema.
Infine, vengono definite le proprietà del sistema che si intende preservare in presenza di attacchi da parte dei Threat Model.

3 Descrizione delle funzionalità del sistema

La funzionalità che si intende realizzare è un sistema per la conduzione di un'elezione elettronica sicura, in cui un avente diritto al voto possa: autenticarsi, ottenere l'autorizzazione al voto , esprimere una sola preferenza al voto, inviare la scheda elettorale ed assicurarsi che il proprio voto sia stato correttamente incluso nel conteggio finale. Il sistema deve infine permettere la pubblicazione di un risultato finale verificabile, riducendo la fiducia richiesta verso un'unica entità centrale.
Per questo motivo, il sistema viene modellato separando logicamente le funzioni descritte; in particolare, il modello separa le funzioni di autenticazione, autorizzazione, raccolta del voto e scrutinio. Il principale motivo di questa scelta è ridurre il rischio che una singola componente possa associare direttamente l'identità reale dell'elettore alla propria preferenza di voto.

4 Modello ad Alto Livello e Attori principali

In questa sezione vengono presentati gli attori principali coinvolti nel modello di voto elettronico proposto e i rispettivi obiettivi. Successivamente viene descritta, ad alto livello, l'interazione tra tali attori durante le diverse fasi dell'elezione: autenticazione dell'elettore, verifica dell'idoneità, autorizzazione al voto, raccolta della scheda, registrazione su un registro verificabile e scrutinio finale.

L'obiettivo della modellazione è chiarire quali responsabilità sono assegnate a ciascuna entità e quali informazioni ciascuna di esse può conoscere e quali invece non deve conoscere.

4.1 Attori Principali

- **Voting Client**:
  Descrizione: interfaccia applicativa attraverso cui l'elettore interagisce con il sistema di voto. Permette di avviare il flusso di autenticazione, ottenere l'accesso alla fase di voto, compilare la scheda e inviarla al sistema.
  Obiettivo: consentire all'elettore di esprimere la propria preferenza e di ricevere le informazioni necessarie per verificare l'inclusione della scheda nel registro.
  Conoscenza: il Client può trattare temporaneamente la preferenza selezionata dall'elettore e le informazioni necessarie all'interazione con il sistema. Tuttavia, nel modello proposto, quest'entità non deve conservare stabilmente dati che permettano di collegare identità reale, autorizzazione e voto espresso. Poiché viene eseguito sul dispositivo dell'utente, non viene considerato una componente pienamente fidata.

- **Identity Service Provider (ISP)**:
  Descrizione: servizio terzo all'applicativo che permette la verifica dell'identità di ogni potenziale elettore.

Obiettivo: verificare che l'utente che richiede accesso al servizio di voto sia effettivamente il soggetto dichiarato.
Conoscenza: l'ISP conosce l'identità reale dell'utente durante la fase di autenticazione. Non gestisce il voto, non decide autonomamente se l'utente può partecipare all'elezione e non conosce la preferenza espressa.

- **Elettore Onesto**:
  Descrizione: persona fisica avente diritto al voto che esprime una sola preferenza valida.
  Obiettivo: autenticarsi correttamente, ottenere l'autorizzazione al voto ed esprimere una preferenza di voto.
  Conoscenza: l'elettore onesto conosce la propria identità reale e la propria preferenza di voto. Una volta inviata la scheda elettorale, non tenta di votare più volte, non ripudia la scelta fatta e non cerca di alterare il corretto funzionamento del sistema.

- **Government Authority**:
  Descrizione: è l'entità che si occupa di verificare l'idoneità alla partecipazione all'elezione per un potenziale elettore onesto, dopo che ha effettuato l'autenticazione per mezzo dell'Identity Service Provider.
  Obiettivo: garantire la partecipazione all'elezione solo agli elettori legittimi e rilasciare per ogni elettore un'autorizzazione che gli permetterà di esercitare il voto.
  Conoscenza: quest'entità deve conoscere l'esito dell'autenticazione, l'identità reale dell'elettore e lo stato di autorizzazione al voto, ma non deve conoscere la sua preferenza espressa al voto.

- **Voting Server**:
  Descrizione: è l'entità incaricata di ricevere le schede elettorali dagli elettori autorizzati e di verificare che ciascun voto provenga da un soggetto abilitato.
  Obiettivo: controllare la validità dell'autorizzazione al voto, impedire l'utilizzo duplicato della stessa credenziale e accettare soltanto voti conformi alle regole dell'elezione. Una volta validato il voto, il Voting Server lo inoltra al Registro Elettorale per la sua registrazione in forma verificabile.
  Conoscenza: il Voting Server non dovrebbe conoscere la vera identità dell'elettore, ma soltanto le informazioni necessarie a stabilire che il voto proviene da un soggetto autorizzato. Inoltre, non dovrebbe conoscere la preferenza in chiaro, ma gestire soltanto una rappresentazione protetta del voto, ad esempio un voto cifrato.

- **Registro Elettorale**:
  Descrizione: è l'entità logica incaricata di conservare i voti validamente accettati dal Voting Server e di renderli pubblicamente verificabili. Nel modello proposto, il Registro Elettorale rappresenta un registro append-only, cioè una struttura in cui i voti registrati non possono essere modificati, rimossi o sostituiti senza che tale alterazione risulti rilevabile.
  Obiettivo: supportare la verificabilità individuale e universale dell'elezione. In particolare, ogni elettore deve poter controllare che il proprio voto sia stato incluso nel registro, mentre osservatori esterni devono poter verificare che il risultato finale sia coerente con l'insieme dei voti registrati.
  Conoscenza: il Registro Elettorale non deve conoscere l'identità reale degli elettori

né la preferenza in chiaro, ma deve conservare solamente informazioni pubblicabili relative ai voti.

- **Scrutiny Authority**:
  Descrizione: si occupa del calcolo finale dei risultati dell'elezione partendo dai dati registrati nel Registro Elettorale.
  Obiettivo: eseguire il conteggio secondo le regole dell'elezione, pubblicando un risultato finale che sia verificabile da tutti.
  Conoscenza: la Scrutiny Authority accede ai dati registrati nel Registro Elettorale e alle informazioni necessarie per eseguire lo scrutinio finale. Nel modello non deve conoscere l'identità reale degli elettori e non deve poter associare una preferenza a uno specifico votante.

4.2 Modellazione del sistema

Il funzionamento del sistema viene modellato come una sequenza di fasi logiche, ciascuna associata a una responsabilità distinta. L'obiettivo di questa separazione è ridurre la fiducia richiesta verso una singola entità centrale e limitare la possibilità che identità reale dell'elettore, autorizzazione al voto e preferenza espressa siano associate direttamente.

1. **Autenticazione dell'elettore tramite Identity Service Provider.**
   Il potenziale elettore accede al sistema tramite il Voting Client e avvia la fase di autenticazione presso l'Identity Service Provider. In questa fase viene verificata l'identità reale dell'utente, senza che siano ancora trattate informazioni relative alla preferenza di voto. L'Identity Service Provider ha quindi il compito di confermare che l'utente sia effettivamente il soggetto dichiarato.

2. **Verifica dell'idoneità da parte della Government Authority.**
   Dopo il completamento dell'autenticazione, la Government Authority verifica che l'utente autenticato sia incluso tra gli aventi diritto per l'elezione considerata. Questa fase distingue l'autenticazione dell'identità dall'autorizzazione al voto: un utente può essere correttamente identificato, ma non necessariamente abilitato a partecipare a quella specifica elezione. In caso di esito negativo, il processo termina e l'utente non viene autorizzato alla votazione.

3. **Rilascio dell'autorizzazione al voto.**
   Se l'utente risulta idoneo, la Government Authority rilascia un'autorizzazione al voto. Nel modello, tale autorizzazione deve consentire al Voting Server di verificare che la scheda provenga da un soggetto abilitato, senza richiedere la conoscenza diretta dell'identità reale dell'elettore durante la fase di raccolta del voto. L'autorizzazione non deve inoltre essere direttamente associabile alla preferenza che sarà successivamente espressa.

4. **Compilazione della scheda tramite Voting Client.**
   L'elettore utilizza il Voting Client per compilare la scheda elettorale, scegliendo una delle opzioni disponibili nel referendum binario. Il Client ha il compito di mostrare correttamente le alternative previste e permettere l'invio della scheda. Nel modello, il Client non deve conservare informazioni che permettano di collegare stabilmente identità reale, autorizzazione e voto espresso.

5. **Invio della scheda al Voting Server e verifica.**
   La scheda viene inviata al Voting Server insieme alle informazioni necessarie a dimostrare l'autorizzazione al voto. Il Voting Server verifica che l'autorizzazione sia valida e che non sia già stata utilizzata per esprimere un voto valido. Questa fase è necessaria per preservare autenticità e unicità del voto. Le schede non valide, duplicate o non conformi alle regole dell'elezione non vengono accettate come voti validi.

6. **Registrazione del voto valido nel Registro Elettorale.**
   Le schede accettate dal Voting Server vengono registrate nel Registro Elettorale, modellato come registro append-only. Tale registro deve rendere rilevabile ogni tentativo successivo di alterazione, rimozione o sostituzione dei voti registrati. A seguito della registrazione, l'elettore ottiene una ricevuta o prova di inclusione che gli consente di verificare la presenza della propria scheda nel registro, senza costituire una prova pubblicamente utilizzabile della preferenza espressa.

7. **Chiusura delle urne.**
   Al termine prestabilito dell'elezione, il sistema non accetta ulteriori schede elettorali. La chiusura delle urne separa la fase di raccolta dalla fase di scrutinio e consente di definire in modo chiaro l'insieme dei voti validi da considerare nel conteggio finale.

8. **Scrutinio finale da parte della Scrutiny Authority e pubblicazione dei risultati.**
   Dopo la chiusura delle urne, la Scrutiny Authority elabora le schede registrate nel Registro Elettorale ed esegue il conteggio finale secondo le regole dell'elezione. Il risultato deve essere pubblicato in forma trasparente e verificabile, in modo che osservatori esterni possano controllare la coerenza tra i voti registrati e il risultato dichiarato. Nel modello, lo scrutinio deve avvenire senza consentire l'associazione diretta tra identità reale dell'elettore e preferenza espressa.

5 Assunzioni di fiducia

Il modello separa le responsabilità tra più entità: autenticazione, autorizzazione, raccolta del voto, registrazione e scrutinio. Tale separazione non elimina la necessità di fidarsi parzialmente di alcune componenti, ma riduce il rischio che una singola entità possa associare direttamente identità reale dell'elettore e preferenza espressa.

Si assume che gli aventi diritto siano già registrati presso un servizio di identificazione digitale riconosciuto, come SPID, CIE o un servizio equivalente. Il modello non include quindi una fase autonoma di registrazione dell'identità digitale, ma delega tale responsabilità a un'infrastruttura esterna.

- **Voting Client**: si assume che mostri correttamente le opzioni previste per il referendum binario e che trasmetta la scheda secondo il flusso previsto dal sistema. Tuttavia, essendo eseguito sul dispositivo dell'elettore, non viene considerato pienamente fidato. Il rischio residuo è che un client compromesso possa osservare la preferenza, modificarla prima dell'invio o conservare dati utili a collegare identità, autorizzazione e voto.

- **Identity Service Provider**: si assume che autentichi correttamente l'identità reale dell'utente e comunichi alla Government Authority un esito di autenticazione corretto. L'ISP è fidato solo per l'identificazione dell'utente, non per stabilire il diritto di voto e non per gestire la preferenza espressa. Il rischio residuo è che un ISP compromesso possa autenticare utenti non legittimi, negare l'accesso a utenti legittimi o favorire correlazioni temporali con le fasi successive.

- **Government Authority**: si assume che verifichi correttamente l'idoneità degli utenti autenticati e rilasci autorizzazioni solo agli elettori aventi diritto. Questa entità deve conoscere l'identità reale dell'elettore per controllarne l'idoneità, ma non deve conoscere la preferenza espressa. Il rischio residuo è che una Government Authority malevola rilasci autorizzazioni indebite, neghi autorizzazioni legittime o conservi metadati temporali utili alla correlazione con la fase di voto.

- **Voting Server**: si assume che verifichi la validità delle autorizzazioni ricevute, impedisca il riutilizzo della stessa autorizzazione e accetti solo schede conformi alle regole dell'elezione. Non è considerato pienamente fidato rispetto alla segretezza del voto: nel modello non deve conoscere l'identità reale dell'elettore né la preferenza in chiaro. Il rischio residuo è che un Voting Server malevolo possa rifiutare voti validi, accettare voti non validi, ritardare la registrazione o conservare metadati utili alla correlazione.

- **Registro Elettorale**: si assume che si comporti come un registro append-only, rendendo rilevabili modifiche, cancellazioni o sostituzioni successive dei voti registrati. Non viene considerato pienamente fidato rispetto alla disponibilità o alla corretta pubblicazione dei dati. Il rischio residuo è che un registro compromesso possa ritardare la pubblicazione, omettere informazioni o rendere più difficile la verifica individuale e universale.

- **Scrutiny Authority**: si assume che esegua il conteggio secondo le regole del referendum binario e pubblichi le informazioni necessarie alla verifica del risultato. Non viene considerata pienamente fidata: una Scrutiny Authority malevola potrebbe pubblicare un risultato scorretto o incompleto. La verificabilità universale ha lo scopo di rendere rilevabili discrepanze tra voti registrati e risultato finale.

5.1 Assunzioni generali del modello

Si assume che nessuna componente sia completamente fidata. La separazione tra autenticazione, autorizzazione, raccolta del voto, registrazione e scrutinio serve a limitare il potere informativo di ciascuna entità.

Si assume inoltre che non vi sia collusione totale tra le componenti principali del sistema. In particolare, una collusione tra Government Authority, Voting Server, Registro Elettorale e Scrutiny Authority potrebbe compromettere lo pseudoanonimato, poiché consentirebbe di collegare identità reale, autorizzazione e scheda registrata.

Infine, si assume che gli avversari considerati non siano in grado di rompere primitive crittografiche correttamente implementate, ma possano sfruttare errori logici, privilegi interni, correlazioni temporali, canali di comunicazione o compromissioni locali, come verrà specificato sucessivamente.

6 Proprietà di Sicurezza da preservare

Il sistema descritto, mira dunque a preservare le seguenti proprietà in presenza di attacchi:

1. **Pseudoanonimato**
   nessuna singola entità deve poter associare direttamente identità reale, autorizzazione e preferenza espressa.

2. **Integrità:**
   I voti inviati non devono in alcun modo essere modificati, soppressi o introdotti in maniera fraudolenta.

3. **Verificabilità individuale:**
   Il singolo elettore deve poter verificare che il proprio voto sia stato registrato correttamente e incluso nel conteggio.

4. **Verificabilità universale:**
   Osservatori esterni devono poter assicurarsi che il referendum sia stato svolto correttamente, senza manomissioni.

5. **Responsabilità dell'emissione delle autorizzazioni:**
   le autorizzazioni al voto emesse dalla Government Authority devono essere tracciabili rispetto all'autorità emittente. In caso di emissione errata o fraudolenta, l'autorità non deve poter negare l'avvenuta emissione. Questa proprietà riguarda l'accountability della fase di autorizzazione e non deve trasformarsi in una prova pubblica della preferenza espressa dall'elettore.

6. **Efficienza:**
   Il modello considera l'efficienza come vincolo progettuale: le operazioni previste devono essere compatibili con un numero elevato di elettori e non devono richiedere costi computazionali sproporzionati per client, server e verificatori

7. **Autenticità:**
   Il requisito di autenticità stabilisce che la partecipazione alla votazione e l'ottenimento della autorizzazione siano riservati esclusivamente agli elettori aventi diritto. L'accesso alla piattaforma di voto è consentito solo a soggetti la cui identità sia stata preventivamente verificata e validata da un'autorità onesta e avente diritto .

8. **Confidenzialità dei dati personali:**
   le informazioni identificative dell'elettore devono essere accessibili solo alle entità che ne hanno bisogno per autenticazione e autorizzazione, e non devono essere propagate alle componenti incaricate della raccolta e dello scrutinio.

9. **Segretezza del voto:**
   la preferenza espressa dal singolo elettore non deve essere rivelata a soggetti non autorizzati e non deve essere osservabile in chiaro durante raccolta, registrazione e scrutinio.

10. **Disponibilità**: il sistema deve rimanere utilizzabile durante il periodo di voto e deve ridurre il rischio che attacchi o malfunzionamenti impediscano a elettori legittimi di partecipare.

11. **Unicità del voto:**
    La proprietà di unicità richiede che ciascun elettore possa esprimere al più un voto valido. Di conseguenza, non deve essere possibile che un elettore possa inviare più di una scheda elettorale valida.

7 Revocabilità e sostituzione del voto

Nel modello base non si consente all'elettore di modificare o sostituire il voto dopo la registrazione della scheda nel Registro Elettorale. Questa scelta semplifica il controllo di unicità e riduce la superficie di attacco legata a replay, contestazioni fraudolente e gestione di più versioni della stessa scheda. La revoca viene considerata solo per le autorizzazioni emesse erroneamente prima del loro utilizzo. In tal caso, l'autorizzazione non viene cancellata, ma marcata come revocata, preservando la tracciabilità dell'emissione e della revoca. Il Voting Server dovrà quindi accettare solo autorizzazioni valide e non revocate. Il rischio residuo è che una Government Authority malevola possa abusare della revoca per impedire a elettori legittimi di votare. Per questo motivo, ogni revoca deve essere tracciabile e giustificabile nell'analisi del modello.

8 Threat Models

In questa sezione verranno identificate le entità atte a compromettere il corretto funzionamento del sistema. Per ogni Threat Model, verranno elencate le sue finalità, le metodologie con cui potrà attaccare l'infrastruttura e le capacità/risorse computazionali con cui performerà le operazioni.

8.1 Elettore disonesto

Il modello è identificato in un elettore che, seppur seguendo il protocollo di voto scelto, cerca di trarre vantaggio da criticità scoperte nel sistema di voto, ad esempio volendo esercitare il suo voto più di una volta, modificare la scelta fatta o ripudiarla.

Finalità

- **Violazione dell'Unicità**: L'elettore disonesto tenta l'espressione di voti multipli per alterare il peso statistico della propria preferenza.
- **Delegittimazione del Processo**: Sfruttare il ripudio sul voto espresso per creare un'apparenza di corruzione nel sistema, inducendo dubbi sulla correttezza del conteggio finale.
- **Collusione o Vendita del Voto**: Dimostrare a terzi la preferenza espressa, in scenari di coercizione o voto di scambio, violando deliberatamente lo pseudoanonimato del proprio voto.

Metodologie di Attacco

- **Replay di autorizzazione**: Sfruttamento della procedura di ottenimento delle credenziali di voto per riutilizzare una credenziale già valida, al fine di esercitare il voto più di una volta, violando quindi l'unicità del voto.

- **Uso improprio di identità o credenziali di terzi**: Utilizzare credenziali cedute volontariamente da familiari, conoscenti o altri elettori per controllare più votazioni. In questo caso l'attacco non mira necessariamente a violare la crittografia del sistema, ma a sfruttare la debolezza del contesto remoto e non presidiato, al fine di aumentare la rilevanza statistica della preferenza espressa.

- **Repudiation Attack / Ripudio Fraudolento**: Disconoscimento formale di un voto correttamente inviato e registrato, sostenendo che l'identità sia stata sottratta o che il sistema abbia fallito la registrazione del voto, al fine di forzare il rilascio di una nuova credenziale di voto e di annullare quella inviata.

- **Proof of vote**: Tentativo di avere una prova ufficiale del voto espresso, salvando eventuali ricevute o prove di voto, al fine di convincere terzi del voto espresso e quindi favorire coercizione o corruzione nel contesto di scambio di voti.

Risorse e Capacità

- **Accesso alle risorse di base**: Ha accesso alle proprie credenziali di voto e al proprio dispositivo, come smartphone o computer.

- **Multi-identità**: Disponibilità di ulteriori identità valide al voto che rendono l'attacco indistinguibile, a livello di rete, da un'operazione lecita.

- **Livello di conoscenza**: Comprensione dettagliata dei flussi di autenticazione tra Government Authority e Client.

8.2 Insider all'interno del Voting Server / Avversario interno privilegiato

Si tratta di un avversario attivo operante all'interno della logica del Voting Server. L'entità, che può essere un amministratore di sistema con privilegi elevati, agisce intenzionalmente per manipolare la corretta verificabilità dei voti da parte del Voting Server, alterando quindi il processo di controllo di duplicati e/o invio di voti leciti al Registro Elettorale.

Finalità

- **Alterazione del metodo di verifica dei voti**: Un insider malevolo potrebbe con i suoi permessi di amministrazione accettare un voto che a priori per le regole stabilite non può essere ritenuto valido, oppure rifiutare un voto che dovrebbe invece essere valido, alterando quindi l'autenticità, unicità e integrità del voto ed erodendo la credibilità del sistema elettorale.

- **Accettazione di duplicati**: L'avversario potrebbe permettere al Voting Server di accettare più voti associati alla stessa autorizzazione o credenziale di voto, violando la proprietà di unicità del voto.

- **Invio di schede di voto non valide**: Siccome il Voting Server ha come obiettivo quello di inviare i voti validi al Registro Elettorale, un insider potrebbe disabilitare i controlli su determinate schede non valide per consentire l'invio di queste schede non valide al Registro Elettorale, invalidando la correttezza del voto.

- **Violazione della Segretezza**: Tentare di de-anonimizzare gli elettori associando l'identità reale alla preferenza espressa, spesso condividendo o vendendo tali dati a terzi.
- **Compromissione delle Chiavi**: Sottrarre chiavi crittografiche sensibili utilizzate per certificare la validità.

Metodologie di Attacco

- **Data Correlation**: Analisi dei log di sistema e dei pacchetti ricevuti per correlare i timestamp e gli indirizzi IP dei votanti con le schede memorizzate nel database.
- **Manomissione del Software**: Modifica del codice sorgente del server di voto per intercettare informazioni sensibili delle schede in chiaro, se non adeguatamente cifrate end-to-end, rifiutare voti validi o validare voti illeciti.
- **Omissione Selettiva**: Cancellazione mirata di schede appartenenti a determinati gruppi di elettori.

Risorse e Capacità

- **Accesso Privilegiato**: Pieni permessi di amministrazione del server di voto, avendo accesso alla logica di validazione e ai record del server.
- **Capacità Operativa**: Potere di manipolare direttamente i record del database e i log del server.
- **Potenza Computazionale**: Disponibilità delle elevate risorse di calcolo e di storage del Voting Server per eseguire analisi di massa sui dati cifrati.

Si assume che l'avversario non sia in grado di rompere le primitive crittografiche correttamente implementate. La forza dell'avversario deriva principalmente dall'accesso al Voting Server e dalla possibilità di alterarne la logica interna di validazione.

8.3 Registro Elettorale compromesso o disonesto

Si considera un avversario interno o una compromissione della componente incaricata di conservare e pubblicare i voti validamente registrati. Nel modello, il Registro Elettorale supporta la verificabilità individuale e universale; pertanto, una sua compromissione può compromettere la fiducia nel risultato finale anche senza violare direttamente la segretezza del voto.

Finalità

- **Alterazione dell'integrità del registro**: modificare, rimuovere o sostituire schede già registrate.
- **Omissione selettiva**: non pubblicare alcune schede validamente accettate dal Voting Server.

- **Compromissione della verificabilità**: impedire agli elettori o agli osservatori esterni di controllare correttamente l'inclusione dei voti e la coerenza del risultato finale.
- **Attacco alla disponibilità**: rendere il registro temporaneamente indisponibile durante o dopo la fase di votazione.

Metodologie di Attacco

- **Cancellazione o sostituzione di schede**: tentativo di rimuovere o modificare voti precedentemente registrati.
- **Pubblicazione incompleta**: pubblicazione di una vista parziale del registro, omettendo selettivamente alcune schede.
- **Ritardo nella pubblicazione**: ritardare la disponibilità dei dati necessari alla verifica individuale o universale.
- **Fork del registro**: presentare versioni differenti del registro a osservatori diversi, generando incoerenza nella verifica.

Risorse e Capacità

- **Accesso ai dati registrati**: possibilità di leggere e tentare di modificare le schede presenti nel registro.
- **Controllo sulla pubblicazione**: capacità di decidere quali informazioni rendere visibili e quando.
- **Capacità operativa**: possibilità di interferire con la disponibilità del registro o con le prove di inclusione.

Si assume che il Registro Elettorale compromesso non sia in grado di rompere primitive crittografiche correttamente implementate. La sua forza deriva dal controllo sulla conservazione e pubblicazione dei dati, non dalla capacità di violare direttamente cifratura o firme.

8.4 Voting Client compromesso o disonesto

L'avversario è configurato come un'entità esterna al modello che tenta di distribuire un software malevolo di voto all'elettore onesto simulando fedelmente l'applicazione ufficiale, compromettendo la fase iniziale di espressione della preferenza, o che cerca di manipolare l'applicativo ufficiale. Essendo il client il mezzo con cui l'elettore interagisce per la compilazione della scheda di voto, un eventuale software compromesso potrebbe osservare la preferenza selezionata prima che essa venga trasmessa al sistema.

Finalità

- **Impersonificazione e Voto Fraudolento**: Il software riesce ad ottenere le informazioni di autenticazione per esprimere un voto al posto dell'elettore legittimo, violando la proprietà di Autenticità.

- **Alterazione della preferenza di voto**: Il client malevolo potrebbe mostrare all'elettore onesto la preferenza selezionata dall'elettore, ma inviare successivamente al Voting Server una preferenza diversa e/o annullarne la trasmissione al Voting Server.
- **Violazione dello pseudonimato**: Il client potrebbe cercare di collegare autenticazione dell'utente reale e preferenza espressa, violando quindi lo pseudonimato.
- **Facilitazione della Coercizione**: Il client malevolo potrebbe salvare i dati della scheda elettorale e della preferenza di voto, inducendo l'elettore a modificare la sua scelta per conto di entità terze, favorendo coercizione.
- **Manipolazione della Verificabilità Individuale**: Impedire all'elettore di accorgersi che il proprio voto è stato alterato o soppresso, fornendo una ricevuta visiva falsa che non corrisponde a quanto effettivamente inviato al server.

Metodologie di Attacco

- **Phishing**: Diffusione di link o eseguibili tramite canali non ufficiali, come email, SMS o social, per indurre l'utente a utilizzare l'interfaccia malevola. In questo modo, quando l'elettore onesto utilizzerà l'applicativo non ufficiale, fornirà i suoi dati sensibili al software malevolo.
- **Conservazione delle informazioni sensibili**: Il client memorizza localmente autorizzazioni, identificativi, ricevute e preferenze per ricostruire il legame tra elettore e voto.
- **Fake Interface**: Creazione di un portale web o di un'applicazione speculare a quella legittima per ingannare l'utente nella fase di inserimento delle credenziali.
- **Credential/Token Forwarding**: Una volta ottenute le credenziali o l'autorizzazione di voto, il client malevolo inoltra queste informazioni alle autorità reali in tempo reale per ottenere i certificati di voto, rendendo l'attacco trasparente all'utente.

Risorse e Capacità

- **Controllo del dispositivo**: L'avversario può controllare totalmente o parzialmente l'ambiente in cui viene eseguito il Voting Client, ad esempio iniettando malware o tramite il client modificato.
- **Ingegneria Sociale e Web Hosting**: Capacità di orchestrare campagne di comunicazione efficaci per l'invio di link malevoli e gestire infrastrutture di hosting per domini malevoli, come cybersquatting o typosquatting.
- **Manipolazione Front-end**: Competenza avanzata nella manipolazione dell'interfaccia utente e dell'esperienza utente per rendere indistinguibile il client falso da quello autentico.
- **Capacità computazionale elevata**: Possesso di uno o più server in grado di eseguire script o algoritmi complessi in poco tempo.

- **Analisi dei Protocolli**: Conoscenza del flusso di comunicazione tra Client, Government Authority e Server per intercettare e reinviare correttamente i messaggi di autorizzazione.
- **Accesso a dati temporanei**: L'avversario può accedere a autorizzazioni, messaggi, conferme o altri dati gestiti localmente durante il protocollo.

8.5 Attaccante esterno

Si definisce come un'entità esterna che non possiede privilegi di accesso diretto alle infrastrutture fisiche o logiche del modello, ma opera attivamente o passivamente sui canali di comunicazione che collegano gli attori del sistema, cioè Elettore, Government Authority e Voting Server.

Può essere definita come:

- **Attaccante passivo**: Un'entità che monitora i canali di comunicazione senza alterare il flusso dei dati o interagire direttamente con i componenti del sistema.
- **Attaccante attivo**: Un avversario che interviene direttamente sulla componente comunicativa, alterando, iniettando, ritardando o eliminando i messaggi scambiati tra le parti oneste, deviando attivamente dal protocollo.

Finalità

- **Compromissione dello Pseudo Anonimato**: Correlare l'identità reale dell'elettore alla preferenza espressa tramite l'analisi dei flussi comunicativi tra gli attori del sistema.
- **Violazione dell'Integrità e dell'Unicità**: Tentare di alterare il conteggio o inserire voti multipli fraudolenti.
- **Attacco alla Disponibilità e alla Legittimità**: Impedire il corretto svolgimento delle operazioni di voto per determinate fasce di elettori o per l'intera infrastruttura, inducendo gli elettori alla contestazione o al ripudio del voto.

Metodologie di Attacco

- **Replay Attack**: Intercettazione delle credenziali degli utenti o del contenuto dei payload, con l'intento di utilizzarli in contesti fraudolenti per violare il vincolo del voto unico.
- **Attacchi Denial-of-Service (DoS)**: Rendere indisponibili le parti oneste del sistema, ad esempio sovraccaricando i server.
- **Man-in-the-Middle (MitM)**: Intercettazione di credenziali o token di autenticazione durante la comunicazione tra il votante lecito e le entità oneste del sistema; l'attaccante può bloccare, effettuando un attacco alla disponibilità, o alterare il contenuto del payload per minare alla legittimità.
- **Eavesdropping e Analisi del Traffico**: Monitoraggio passivo del traffico tra l'utente e le autorità per estrarre dati atti a identificare pattern comportamentali e dati sensibili violando così la segretezza.

- **Sabotaggio della Fiducia**: Sfruttamento di bug minori, latenze o inefficienza di sistema per amplificare dubbi sulla sicurezza, spingendo gli utenti a dichiarare falsamente che il proprio voto è stato manipolato e spingendo al ripudio del voto a quest'ultimi.

Risorse e Capacità

- **Capacità Computazionali**: Esse possono variare dipendentemente dall'organizzazione che genera questo tipo di attacchi. L'attaccante può avere accesso a più dispositivi per eseguire analisi massive di dati in transito su canali non protetti o eseguire attacchi DoS compromettendo il funzionamento dei server.
- **Capacità di intercettazione**: Capacità di intercettazione su canali non protetti.

8.6 Government Authority Disonesta

L'avversario si configura come l'opposto della parte onesta rappresentata dalla Government Authority, cioè l'entità che è incaricata di verificare l'idoneità dell'elettore e di rilasciare un'autorizzazione valida al voto. Nel modello proposto, questa entità occupa una posizione critica perché conosce l'entità reale dell'elettore e il suo stato di abilitazione al voto. Configurandosi come disonesta, questa entità ha come obiettivo quello di alterare il processo di autorizzazione, rilasciando credenziali indebite, negandole ad elettori legittimi o conservando informazioni utili per correlare identità e successive fasi di partecipazione al voto. La separazione tra le entità discussa precedentemente riduce il rischio di correlazione tra i dati di ogni singolo elettore onesto, tuttavia non esclude il rischio che l'autorità che dovrebbe verificare l'autorizzazione al voto possa comportarsi maliziosamente abusando dei propri poteri.

Finalità

- **Rilascio di autorizzazioni indebite**: Può rilasciare credenziali o autorizzazioni al voto a soggetti non aventi diritto, consentendo la partecipazione illegittima all'elezione.
- **Negazione di autorizzazioni valide**: Revoca dell'autorizzazione al voto per specifici elettori legittimi, impedendo loro di esercitare il diritto di voto e compromettendo quindi la correttezza del processo elettorale.
- **Collegamento identità-voto**: Avendo accesso diretto all'identità di ogni elettore per poterne verificare l'idoneità al voto, potrebbe conservare informazioni dettagliate su ogni elettore, favorendo quindi la creazione di un collegamento tra l'identità reale dell'elettore e la successiva operazione di voto.

Metodologie di Attacco

- **Manipolazione del registro aventi diritto**: Marcando ad esempio come non idoneo un elettore legittimo o come idoneo un soggetto non autorizzato.
- **Emissione fraudolenta di autorizzazioni**: Rilascio intenzionale di autorizzazioni o credenziali di voto non giustificate da una corretta autenticazione e verifica di idoneità.

- **Emissione multipla per lo stesso elettore**: Rilascio di più autorizzazioni per una stessa identità reale, violando la proprietà di unicità.
- **Collusione con altre componenti**: Condivisione intenzionale di dati con altre entità, al fine di facilitare la correlazione tra identità e voto registrato.

Risorse e Capacità

- **Accesso al registro degli aventi diritto al voto**: Possibilità di modificare e leggere lo stato degli elettori ammessi alla votazione.
- **Controllo fase di autorizzazione**: Capacità di revocare, negare, rilasciare o duplicare autorizzazioni di voto.
- **Conoscenza dell'identità degli elettori**: Accesso ai dati identificativi degli elettori autenticati tramite Identity Service Provider.
- **Accesso a log di autorizzazione**: Disponibilità di informazioni temporali relative alle richieste di autorizzazione.

È doveroso inoltre precisare che non si assume che la Government Authority malevola sia in grado di rompere primitive crittografiche implementate correttamente. La sua forza deriva unicamente dal ruolo istituzionale e operativo che ricopre, potendo controllare la decisione su chi può ricevere diritto al voto e conoscere l'identità degli elettori.

8.7 Scrutiny Authority compromessa o disonesta

Si definisce come un avversario interno che corrompe il corretto funzionamento dell'autorità di scrutinio oppure come una Scrutiny Authority stessa malevola. Tale entità gode di privilegi elevati nella fase finale dell'elezione, poiché il suo compito onesto è calcolare l'esito finale a partire dai voti presenti nel Registro Elettorale e pubblicare un risultato verificabile.

Nel modello proposto, la Scrutiny Authority non dovrebbe conoscere l'identità reale degli elettori, né dovrebbe modificare l'insieme dei voti registrati. Tuttavia, se compromessa o disonesta, può tentare di alterare la correttezza dello scrutinio, pubblicare un risultato non coerente con i voti registrati oppure collaborare con altre componenti per indebolire la segretezza del voto.

Finalità

- **Falsificazione del conteggio**: Pubblicare un risultato finale diverso da quello ottenibile applicando correttamente le regole di scrutinio ai voti presenti nel Registro Elettorale.
- **Omissione selettiva di voti registrati**: Escludere dal conteggio voti regolarmente presenti nel Registro Elettorale, con l'obiettivo di alterare l'esito finale.
- **Delegittimazione del processo**: Pubblicare risultati incompleti, incoerenti o non verificabili, inducendo dubbi sulla correttezza della procedura elettorale.

- **Violazione della segretezza**: Tentare di ricavare informazioni sulle preferenze individuali durante la fase di scrutinio, soprattutto in caso di accesso a dati ausiliari o collusione con altre componenti del sistema.
- **Collusione per la de-anonimizzazione**: Collaborare con Government Authority, Voting Server o Registro Elettorale per tentare di collegare identità reale, autorizzazione e scheda registrata.

Metodologie di Attacco

- **Conteggio scorretto**: Applicazione intenzionalmente errata delle regole di scrutinio previste per il referendum binario.
- **Esclusione selettiva**: Mancato conteggio di alcune schede presenti nel Registro Elettorale.
- **Pubblicazione fraudolenta del risultato**: Pubblicazione di un risultato finale non coerente con l'insieme dei voti registrati.
- **Falsificazione o omissione delle informazioni di verifica**: Mancata pubblicazione delle informazioni necessarie a consentire la verifica universale del risultato.
- **Collusione con altre entità**: Condivisione di informazioni con altre componenti del sistema per tentare la correlazione tra elettori e schede.

Risorse e Capacità

- **Accesso ai dati di scrutinio**: Disponibilità dei voti presenti nel Registro Elettorale necessari per il calcolo del risultato finale.
- **Controllo della procedura di conteggio**: Capacità di influenzare o manipolare il calcolo dell'esito elettorale.
- **Controllo sulla pubblicazione del risultato**: Capacità di pubblicare risultati finali, risultati parziali o informazioni di verifica non coerenti con i voti registrati.
- **Capacità di collusione**: Possibilità di condividere dati o metadati con altre componenti del sistema, al fine di compromettere pseudoanonimato, segretezza o trasparenza.

Si assume che la Scrutiny Authority compromessa non possa modificare direttamente l'elenco degli aventi diritto o rilasciare autorizzazioni di voto, poiché tali funzioni appartengono alla Government Authority. Inoltre, non si assume che possa rompere primitive crittografiche correttamente implementate. La sua forza deriva dal controllo sulla fase di conteggio e dalla possibilità di pubblicare un risultato finale scorretto o non sufficientemente verificabile.

9 Priorità , Compromessi e Rischi Residui

Il modello proposto prioritizza autenticità, unicità, integrità e verificabilità, poiché tali proprietà sono necessarie per garantire che solo elettori legittimi possano partecipare, che ciascuno possa esprimere al più un voto valido e che il risultato finale sia controllabile dagli elettori e da osservatori esterni.

La segretezza del voto e lo pseudoanonimato vengono perseguiti tramite la separazione tra autenticazione, autorizzazione, raccolta del voto e scrutinio. Tuttavia, il modello non garantisce anonimato assoluto: una collusione tra Government Authority, Voting Server, Registro Elettorale e Scrutiny Authority potrebbe consentire la correlazione tra identità reale, autorizzazione e scheda registrata.

La verificabilità individuale richiede che l'elettore possa controllare l'inclusione della propria scheda nel Registro Elettorale. Tuttavia, tale verifica non deve trasformarsi in una prova pubblicamente utilizzabile della preferenza espressa, altrimenti aumenterebbe il rischio di coercizione e compravendita del voto.

Il modello non elimina completamente coercizione e voto di scambio, poiché il voto avviene in un ambiente remoto non presidiato. Un elettore potrebbe essere controllato fisicamente da terzi, utilizzare un client compromesso oppure produrre prove esterne della propria scelta, ad esempio tramite registrazioni o screenshot. Il sistema mira quindi a ridurre la produzione di prove trasferibili, ma non può garantire la stessa protezione offerta da un seggio fisico controllato.

Nel modello base non si consente la sostituzione del voto dopo la registrazione della scheda. Questa scelta semplifica il controllo di unicità e riduce i rischi legati a replay, contestazioni fraudolente e gestione di versioni multiple della stessa scheda. La revoca viene considerata solo per autorizzazioni emesse erroneamente prima del loro utilizzo, mantenendo comunque tracciabile l'emissione originaria.

L'efficienza viene trattata come vincolo progettuale . Il modello deve evitare interazioni troppo lunghe, concentrazione eccessiva del carico su una singola componente e meccanismi non proporzionati al contesto applicativo. La valutazione quantitativa di tempi, dimensione dei messaggi e costi computazionali sarà demandata al WP4.

Infine , la disponibilità è considerata una proprietà importante ma non assoluta. Attacchi di tipo denial-of-service, malfunzionamenti o ritardi nella pubblicazione dei dati possono impedire ad alcuni elettori di partecipare o rendere più difficile la verifica. Il modello richiede quindi che tali rischi siano considerati nella progettazione, pur riconoscendo che non possono essere eliminati completamente.